2019 EXAMINATIONS

Part II

COMPUTING AND COMMUNICATIONS [2 Hours]

SCC.363 Security and Risk

Candidates are asked to answer THREE questions from FOUR; each question is worth a total of 20 marks.

Use a separate answer book for each question.

Question 1

1.a Describe four attack models for symmetric ciphers in terms of the adversary's ability to obtain ciphertexts/plaintexts.

[8 marks]

1.b During World War II, allied codebreakers at Bletchley Park would sometimes ask the Royal Air Force to lay mines at a position that didn't have any abbreviations or alternatives in the German naval system's grid reference. The hope was that the Germans, seeing the mines, would use an Enigma machine to encrypt a warning message about the mines and an "all clear" message after they were removed. Those cryptograms were then intercepted and provided the allies with enough information about the message to break the German naval Enigma.

Who is the adversary? And what is the attack model for the above scenario w.r.t. breaking Enigma?

[3 marks]

1.c Answer the following questions about stream cipher.

i. Does a stream cipher achieve perfect secrecy? Why? **[4 marks]**

ii. Is it secure to use the same key to encrypt two different messages using a stream cipher? Why? **[5 marks]**

Total 20 marks

Question 2

2.a Define the collision resistant property.

[3 marks]

2.b Let f(x) = (2*x + 4) mod 11.

i. Is the function f(x) collision resistant? Why? **[4 marks]**

2.c If a hash function H() is collision resistant, is it possible to use it as an encryption scheme? For instance, to encrypt message **M** with key **K**, we compute H(K,M). Justify your result.

[4 marks]

2.d H1() and H2() are two collision resistant hash functions. Are the following constructions collision resistant? Justify your results. (|| stands for concatenation)

i. H3(x) = H1(H2(x) || H2(0000)) **[3 marks]**

ii. H4(x) = H1(x) **XOR** H2(1234) **[3 marks]**

iii. H5(x) = H1(3*x) || H2(5*x) **[3 marks]**

Total 20 marks

Question 3

3.a DNS cache poisoning

i. What is DNS cache poisoning? Explain how the attack is performed, and its effects.

[6 marks]

ii. Describe one defence against DNS cache poisoning.

[2 marks]

3.b

i. What is the “flash crowds” attack?

[2 marks]

ii. Explain how the TCP handshake can be used to carry out a Denial of Service attack.

[4 marks]

3.c Megacorp LLC has hired you to test the security of their organisation. One thing in particular they want you to test is the security of their development team, in particular the secrecy about new products in development, and the risk of this being leaked.

Describe, in detail, the steps you would take in order to try and gain a copy of the latest software without exploiting any machines. Assume you are starting from fresh, with no knowledge of the organisation other than its name.

[6 marks]

Total 20 marks

Question 4

4.a Describe the Chinese wall security policy and BLP (Bell-LaPadula) policy. Compare these two security policies.

[6 marks]

4.b A lawyer specialises in product liability and consults for American Airlines.

i. Can the lawyer also be a consultant for United Airlines? Why? **[1 marks]**

ii. Can the lawyer have a part-time contract with McDonalds? Why? **[1 marks]**

4.c Your computer has a malware. Can BLP policy prevent the malware from stealing your sensitive information? Justify your answer.

[3 marks]

4.d A system has five users Alice, Bob, Charlie, Diana, and Eve. Each of the users is assigned a label: Alice is Confidential, Bob is Restricted, Charlie is Confidential, Diana is Secret, Eve is Top Secret. Each user creates a document, and when they create a document the document gets the same label as the user who created it. Alice creates Document A, Bob creates Document B, Charlie creates Document C, Diana creates Document D, and Eve creates Document E.

According to BLP policy, please copy the following table to the answer sheet and fill it, showing what happens when someone tries to read a document. (Put **allow/deny** in each cell.)

	Doc A	Doc B	Doc C	Doc D	Doc E
Alice					
Bob					
Charlie					
Diana					
Eve					

[4 marks]

Question 4 continues on next page…

Question 4 continued.

4.e Imagine a BLP-like secure system with the following five operations.

- (READ, s, o): if the subject and object exist and L(s) ≥ L(o), the subject obtains the current value of the object; otherwise, do nothing.
- (WRITE, s, o, v): if the subject and object exist and L(s) ≤ L(o), the object gets value v; otherwise, do nothing.
- (CREATE, s, o): add a new object with the given name, a level equal to the subject's level, and an initial value of 0. If an object of that name exists, do nothing.
- (DESTROY, s, o): eliminate the designated object from the state, assuming that the object exists and the subject has WRITE access to it. Otherwise, do nothing.

Describe a covert channel in this system. That is, show a series of instructions that will send a 0 from high to low, and another that will send a 1 from high to low.

[5 marks]

Total 20 marks

--- End of Paper ---